tellius

Tellius, Inc.

TABLE OF CONTENTS

Access Control Policy	**2**
Asset Management Policy	**6**
Business Continuity and Disaster Recovery Plan	**8**
Code of Conduct	**12**
Cryptography Policy	**16**
Data Management Policy	**18**
Human Resource Security Policy	**23**
Incident Response Plan	**26**
Information Security Policy (AUP)	**31**
Information Security Roles and Responsibilities	**37**
Operations Security Policy	**40**
Physical Security Policy	**44**
Risk Management Policy	**47**
Secure Development Policy	**51**
Third-Party Management Policy	**56**

Access Control Policy

Policy Owner: VP, Operations & Strategy

Effective Date: 01/01/2025

Purpose

To limit access to information and information processing systems, networks, and facilities to authorized parties in accordance with business objectives.

Scope

All Tellius, Inc. information systems that process, store, or transmit confidential data as defined in the Tellius, Inc. Data Management Policy. This policy applies to all employees of Tellius, Inc. and to all external parties with access to Tellius, Inc. engineering networks and system resources.

Policy

Access to information computing resources is limited to personnel with a business requirement for such access. Access rights shall be granted or revoked in accordance with this Access Control Policy.

Business Requirements of Access Control

Access Control Policy

Tellius, Inc. shall determine the type and level of access granted to individual users based on the "principle of least privilege." This principle states that users are only granted the level of access absolutely required to perform their job functions, and is dictated by Tellius, Inc.'s business and security requirements. Permissions and access rights not expressly granted shall be, by default, prohibited.

Tellius, Inc.'s primary method of assigning and maintaining consistent access controls and access rights shall be through the implementation of Role-Based Access Control (RBAC). Wherever feasible, rights and restrictions shall be allocated to groups. Individual user accounts may be granted additional permissions as needed with approval from the system owner or authorized party.

All privileged access to production systems should use Multi-Factor Authentication (MFA).

Access to Networks and Network Services

The following security standards shall govern access to Tellius, Inc. networks and network services:

- Technical access requests to Tellius, Inc. networks must be documented via standard communication channels (email or Slack) and include the standard role and the business need for access.
- Only authorized Tellius, Inc. employees and third-parties working off a signed contract or statement of work, with a business need, shall be granted access to the Tellius, Inc. production networks
- Tellius, Inc. guests may be granted access to guest networks after registering with office staff without a documented request
- Remote connections to production systems and networks must be encrypted

User Access Management

Tellius, Inc. requires that all personnel have a unique user identifier for system access, and that user credentials and passwords are not shared between multiple personnel. Users with multiple levels of access (e.g. administrators) should be given separate accounts for normal system use and for administrative functions wherever feasible. Root, service, and administrator accounts may use a password management system to share passwords for business continuity purposes only. Administrators shall only use shared administrative accounts as needed.

User Registration and Deregistration

Only authorized administrators shall be permitted to create new user IDs, and may only do so upon receipt of a documented request from authorized parties. User provisioning requests must include approval from data owners or Tellius, Inc. management authorized to grant system access. Prior to account creation, administrators should verify that the account does not violate any Tellius, Inc. security or system access control policies such as segregation of duties, fraud prevention measures, or access rights restrictions.

User IDs shall be promptly disabled or removed when users leave the organization or contract work ends. User IDs shall not be re-used.

User Access Provisioning

- New employees and/or contractors are not to be granted access to any Tellius, Inc. production systems until after they have completed all HR on-boarding tasks, which may include but is not limited to signed employment agreement, intellectual property agreement, and information security policy
- Access should be restricted to only what is necessary to perform job duties
- No access may be granted earlier than official employee start date
- Access requests and rights modifications shall be documented in an access request ticket or email or Slack communication directly to systems administrators. No permissions shall be granted without approval from the system or data owner or management
- Records of all permission and privilege changes shall be maintained for no less than one year

Management of Privileged Access

Granting of administrative rights shall be strictly controlled, and requires approval from the asset owner.

User Access Reviews

Administrators shall perform access rights reviews of user, administrator, and service accounts on a quarterly basis to verify that user access is limited to systems that are required for their job function. Access reviews shall be documented.

Access reviews may include group membership as well as evaluations of any specific or exception-based permission. Access rights shall also be reviewed as part of any job role change, including promotion, demotion, or transfer within the company.

Removal & Adjustment of Access Rights

The access rights of all users shall be promptly removed upon termination of their employment or contract, or when rights are no longer needed due to a change in job function or role. The maximum allowable time period for access termination is 16 business hours (2 business days).

Access Provisioning, Deprovisioning, and Change Procedure

The Access Management Procedure for Tellius, Inc. systems can be found in Appendix A to this policy.

User Responsibility for the Management of Secret Authentication Information

Control and management of individual user passwords is the responsibility of all Tellius, Inc. personnel and third-party users. Users shall protect secret authentication information in accordance with the Information Security Policy.

Password Policy

Where feasible, passwords for confidential systems shall be configured for at least eight (8) characters, one upper case, one number. All employees need an active Password Manager on their devices to assist in managing reasonable password strength across systems of access.

System and Application Access

Information Access Restriction

Applications must restrict access to program functions and information to authorized users and support personnel in accordance with the defined access control policy. The level and type of restrictions applied by each application should be based on the individual application requirements, as identified by the data owner. The application-specific access control policy must also conform to Tellius, Inc. policies regarding access controls and data management.

Prior to implementation, evaluation criteria are to be applied to application software to determine the necessary access controls and data policies. Assessment criteria include, but are not limited to:

- Sensitivity and classification of data.
- Risk to the organization of unauthorized access or disclosure of data
- The ability to, and granularity of, control(s) on user access rights to the application and data stored within the application
- Restrictions on data outputs, including filtering sensitive information, controlling output, and restricting information access to authorized personnel
- Controls over access rights between the evaluated application and other applications and systems
- Programmatic restrictions on user access to application functions and privileged instructions
- Logging and auditing functionality for system functions and information access
- Data retention and aging features

All unnecessary default accounts must be removed or disabled before making a system available on the network. Specifically, vendor default passwords and credentials must be changed on all Tellius, Inc. systems, devices, and infrastructure prior to deployment. This applies to ALL default passwords, including but not limited to those used by operating systems, software that provides security services, application and system accounts, and Simple Network Management Protocol (SNMP) community strings where feasible.

Secure Log-on Procedures

Secure log-on controls shall be designed and selected in accordance with the sensitivity of data and the risk of unauthorized access based on the totality of the security and access control architecture.

Password Management System

Systems for managing passwords should be interactive and assist Tellius, Inc. personnel in maintaining password standards by enforcing password strength criteria including minimum length, and password complexity where feasible.

All storage and transmission of passwords is to be protected using appropriate cryptographic protections, either through hashing or encryption.

Use of Privileged Utility Programs

Use of utility programs, system files, or other software that might be capable of overriding system and application controls or altering system configurations must be restricted to the minimum personnel required. Systems are to maintain logs of all use of system utilities or alteration of system configurations. Extraneous system utilities or other privileged programs are to be removed or disabled as part of the system build and configuration process.

Management approval is required prior to the installation or use of any ad hoc or third-party system utilities.

Access to Program Source Code

Access to program source code and associated items, including designs, specifications, verification plans, and validation plans shall be strictly controlled in order to prevent the introduction of unauthorized functionality into software, avoid unintentional changes, and protect Tellius, Inc. intellectual property.

All access to source code shall be based on business need and must be logged for review and audit.

Exceptions

Requests for an exception to this Policy must be submitted to the Policy Owner for approval.

Violations & Enforcement

Any known violations of this policy should be reported to the Policy Owner. Violations of this policy can result in immediate withdrawal or suspension of system and network privileges and/or disciplinary action in accordance with company procedures up to and including termination of employment.

Version	Date	Description	Author	Approved by
1.0	01-Jan-2025	First Version		
2.0				

APPENDIX A - Access Management Procedure

At the completion of the onboarding process, Operations will send via Email invites to the access to the systems that match the job description of the employee.

Additional access, beyond standard pre-approved access, must be requested and approved by a manager or system owner.

The access provisioning procedures are maintained by the Operations Lead.

Asset Management Policy

Policy Owner: VP, Operations & Strategy
Effective Date: 01/01/2025

Purpose

To identify organizational assets and define appropriate protection responsibilities. This policy ensures that information receives an appropriate level of protection in accordance with its importance to the organization. It aims to prevent unauthorized disclosure, modification, removal, or destruction of information stored on company-owned media and devices.

Scope

This policy applies to all Tellius, Inc.-owned or managed information systems, hardware, and digital assets.

Policy

Inventory of Assets

- All assets associated with information and information processing facilities that store, process, or transmit classified information shall be identified and documented in an inventory.
- The asset inventory can be accessed in Vanta, and the Finance team also maintains records for financial tracking.
- The asset inventory shall be regularly reviewed and updated to ensure accuracy and compliance with company security policies.
- All assets associated with information and information processing facilities that store, process, or transmit classified information shall be identified and documented in an inventory.
- The asset inventory shall be regularly reviewed and updated to ensure accuracy and compliance with company security policies.

Ownership of Assets

- Each asset in the inventory shall be assigned an owner, either an individual or a designated team within Tellius, Inc.
- Asset owners are responsible for ensuring appropriate security measures and maintenance of their assigned assets.

Acceptable Use of Assets

- Rules for the acceptable use of company information, assets, and information processing facilities are outlined in the Information Security Policy.
- Employees must use company assets only for authorized business purposes and in accordance with company policies.

Return of Assets

- All employees, contractors, and third-party users must return all Tellius, Inc. assets in their possession upon termination of their employment, contract, or agreement.
- The IT and Operations teams will verify the return and condition of assets before processing offboarding requests.

Handling of Assets

- Employees and users who are issued or handle Tellius, Inc. equipment must exercise due care and responsibility in protecting and maintaining the equipment.
- Company equipment must be secured and properly attended to whenever transported or stored outside of company facilities.
- Any lost, stolen, or damaged assets must be reported immediately to the Policy Owner and IT team.

Asset Disposal

- Obsolete or decommissioned assets must be disposed of securely to prevent unauthorized access to company data.
- Data on retired assets must be wiped or destroyed following industry best practices and company security guidelines.

Exceptions

- Requests for exceptions to this policy must be submitted in writing to the Policy Owner for review and approval.

Violations & Enforcement

- Any known violations of this policy must be reported to the Policy Owner.
- Violations can result in withdrawal or suspension of system and network privileges and/or disciplinary action up to and including termination of employment, in accordance with company procedures.

By adhering to this policy, Tellius, Inc. ensures proper governance over company assets, safeguarding both company and client information.

Tellius Business Continuity and Disaster Recovery Policy

Policy Owner: VP of Engineering

Effective Date: 01/01/2025

1. Purpose

- This policy establishes the framework for ensuring the continuity of Tellius's critical business functions and the recovery of its IT infrastructure in the event of disruptions. It ensures that Tellius:
  - Maintains the availability of essential business operations.
  - Minimizes the impact of disruptions on customers, partners, and stakeholders.
  - Recovers critical systems and data in a timely manner.
  - Complies with relevant legal, regulatory, and contractual obligations, including the AICPA's Trust Services Criteria for SOC 2.

2. Scope

- This policy applies to all Tellius business functions, information systems, and technology infrastructure, including but not limited to:
  - Essential business processes
  - Applications
  - Systems
  - Networks
  - Data
  - Hardware
  - Software
  - Cloud services
  - Facilities
  - Personnel

3. Policy Statements

- **Business Continuity Plan (BCP):** Tellius maintains a comprehensive Business Continuity Plan (BCP) that outlines procedures for sustaining essential business functions during disruptions. The BCP is regularly reviewed and updated.
- **Disaster Recovery Plan (DRP):** Tellius has a detailed Disaster Recovery Plan (DRP) that outlines the procedures for recovering IT infrastructure and data following a disaster. The DRP is tested and validated.
- **Risk Assessment:** Business impact analyses and risk assessments are conducted to identify critical business functions and potential threats.
- **Backup and Recovery:** Data is regularly backed up, and recovery procedures are established and tested to ensure data can be restored in a timely manner.
- **Redundancy and Resilience:** Systems and infrastructure are designed with redundancy and resilience to minimize single points of failure and ensure high availability.
- **Communication Plan:** A communication plan is in place to ensure timely and effective communication with stakeholders during a disruption.

- **Training and Awareness:** Personnel receive training and awareness education on their roles and responsibilities in business continuity and disaster recovery.

4. Procedures

- **Business Continuity Plan (BCP)**
  - **BCP Development and Maintenance:**
    - The BCP is developed, documented, and maintained by the designated Business Continuity team.
    - The BCP includes the following key elements:
      - Scope and objectives
      - Business impact analysis (BIA)
      - Risk assessment
      - Recovery strategies for critical business functions
      - Communication plan
      - Roles and responsibilities
      - Plan testing and exercises
      - Plan maintenance and updates
  - **Business Impact Analysis (BIA):**
    - A Business Impact Analysis (BIA) is conducted to identify critical business functions and assess the potential impact of disruptions on these functions.
    - The BIA considers financial, operational, legal, and reputational impacts.
  - **Risk Assessment:**
    - Risk assessments are performed to identify potential threats that could disrupt business operations, such as:
      - Natural disasters
      - Cyberattacks
      - Pandemics
      - Infrastructure failures
      - Human error
    - The likelihood and impact of these threats are evaluated.
  - **Recovery Strategies:**
    - Recovery strategies are developed for each critical business function, including:
      - Alternative work locations
      - Remote work arrangements
      - Manual workarounds
      - Data backup and restoration
      - System redundancy
  - **Communication Plan:**
    - A communication plan is established to ensure timely and effective communication with internal and external stakeholders during a disruption.
    - The plan includes:
      - Contact information for key personnel
      - Communication channels (e.g., email, phone, website)
      - Notification procedures
      - Stakeholder communication templates
  - **BCP Testing and Exercises:**
    - The BCP is tested and exercised regularly to validate its effectiveness and identify areas for improvement.
    - Testing includes:
      - Tabletop exercises
      - Functional exercises
      - Full-scale simulations

        - Testing results are documented, and the BCP is updated as needed.
    - **BCP Maintenance and Updates:**
        - The BCP is reviewed and updated at least annually or more frequently following significant changes to the business or IT environment.
- **Disaster Recovery Plan (DRP)**
    - **DRP Development and Maintenance:**
        - A Disaster Recovery Plan (DRP) is developed, documented, and maintained by the IT department in coordination with the Business Continuity team.
        - The DRP includes:
            - Scope and objectives
            - Recovery time objectives (RTOs) and recovery point objectives (RPOs)
            - Recovery procedures for IT systems and data
            - Backup and restoration procedures
            - Alternate processing site information
            - System and network diagrams
            - Vendor contacts
            - Testing procedures
    - **Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs):**
        - Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) are defined for each critical system and application.
        - RTOs and RPOs are aligned with business needs and risk tolerance.
    - **Backup and Restoration:**
        - Data backups are performed regularly, and backup procedures are documented and tested.
        - Backups are stored securely, both on-site and off-site.
        - Data restoration procedures are established and tested to ensure data can be recovered within the defined RTO.
    - **Alternate Processing Site:**
        - An alternate processing site (e.g., a hot site, warm site, or cold site) is identified and maintained, if necessary.
        - The alternate site is equipped with the necessary hardware, software, and network connectivity to resume critical operations.
    - **DRP Testing and Exercises:**
        - The DRP is tested and exercised regularly to validate its effectiveness and identify areas for improvement.
        - Testing includes:
            - Component testing
            - Functional testing
            - Full-scale disaster recovery simulations
        - Testing results are documented, and the DRP is updated as needed.
    - **DRP Maintenance and Updates:**
        - The DRP is reviewed and updated at least annually or more frequently following significant changes to the IT infrastructure or business operations.

5. Roles and Responsibilities

- **Executive Management:**
    - Provides overall direction and support for business continuity and disaster recovery planning.
    - Approves the BCP and DRP.
    - Ensures that adequate resources are allocated for business continuity and disaster recovery.
- **Business Continuity Team:**

    - Develops, maintains, and tests the BCP.
    - Conducts business impact analyses and risk assessments.
    - Coordinates communication with stakeholders during a disruption.
    - Manages the recovery of business operations.
- **IT Department:**
    - Develops, maintains, and tests the DRP.
    - Implements and maintains backup and recovery systems.
    - Ensures the availability and resilience of IT infrastructure.
    - Assists with the recovery of IT systems and data during a disaster.
- **Department Heads:**
    - Identify critical business functions within their departments.
    - Participate in the development of department-specific recovery procedures.
    - Ensure that their staff are trained on their roles and responsibilities in the BCP.
- **All Personnel:**
    - Responsible for understanding their roles and responsibilities in the BCP and DRP.
    - Cooperating with the BCP and DRP during a disruption.

6. Compliance

- **6.1 Policy Compliance:** All Tellius personnel and third parties are required to comply with this policy.
- **6.2 Non-Compliance:** Non-compliance with this policy may result in disciplinary action, up to and including termination of employment or contracts, and potential legal consequences.
- **6.3 Policy Review:** This policy and the associated BCP and DRP will be reviewed and updated at least annually or as needed to reflect changes in technology, business requirements, or regulatory requirements.

Vanta

Code of Conduct

Policy Owner: Abhishek Panigrahi, VP - Strategy & Operations

Effective Date: 02/01/2025

Purpose

The primary goal of Tellius, Inc.'s Code of Conduct is to foster inclusive, collaborative and safe working conditions for all Tellius, Inc. staff. As such, Tellius, Inc. is committed to providing a friendly, safe and welcoming environment for all staff, regardless of gender, sexual orientation, ability, ethnicity, socioeconomic status, or religion (or lack thereof).

This code of conduct outlines our expectations for all Tellius, Inc. staff, as well as the consequences for unacceptable behavior.

Scope

The Code of Conduct applies to all Tellius, Inc. staff. This includes full-time, part-time and contractor staff employed at every seniority level. The Code of Conduct is to be upheld during all professional functions and events, including but not limited to business hours at the Tellius, Inc. office, during Tellius, Inc.-related extracurricular activities and events, while attending conferences and other professional events on behalf of Tellius, Inc., and while working remotely and communicating on Tellius, Inc. resources with other staff.

We expect all Tellius, Inc. staff to abide by this Code of Conduct in all business matters -- online and in-person -- as well as in all one-on-one communications with customers and staff pertaining to Tellius, Inc. business.

This Code of Conduct also applies to unacceptable behavior occurring outside the scope of business activities when such behavior has the potential to adversely affect the safety and well-being of Tellius, Inc. staff and clients.

Culture and Citizenship

A supplemental goal of this Code of Conduct is to increase open citizenship by encouraging participants to recognize the relationships between our actions and their effects within Tellius, Inc. culture.

Be welcoming. We strive to be a company that welcomes and supports people of all backgrounds and identities. This includes, but is not limited to members of any race, ethnicity, culture, national origin, color, immigration status, social and economic class, educational level, sexual orientation, gender identity and expression, age, size, family status, political belief, religion, and mental and physical ability.

Be considerate. Your work at Tellius, Inc. will be used by other people, and you in turn will depend on the work of others. Any decision you take will affect users and colleagues, and you should take those consequences into account when making decisions.

Be respectful. Not all of us will agree all the time, but disagreement is no excuse for poor behavior and poor manners. We might all experience some frustration now and then, but we cannot allow that frustration to turn into a personal attack. It's important to remember that a company where people feel uncomfortable or threatened is neither productive nor pleasant. Tellius, Inc. staff should always be respectful when dealing with other personnel as well as with people outside of Tellius, Inc. employment.

Acceptable and Expected Behavior

The following behaviors are expected and requested of all Tellius, Inc. staff:

- Participate in an authentic and active way. In doing so, you contribute to the health and longevity of Tellius, Inc..
- Exercise consideration and respect in your speech and actions at all times.
- Attempt collaboration before conflict.
- Refrain from demeaning, discriminatory, or harassing behavior and speech.
- Be mindful of your surroundings and of your fellow participants. Alert Tellius, Inc. leaders if you notice a dangerous situation, someone in distress, or violations of this Code of Conduct, even if they seem inconsequential.
- Remember that Tellius, Inc. events may be shared with members of the public and Tellius, Inc. customers; please be respectful to all patrons of these locations at all times

Unacceptable Behavior

The following behaviors are considered harassment and are unacceptable within our community:

- Violence, threats of violence or violent language directed against another person.
- Sexist, racist, homophobic, transphobic, ableist or otherwise discriminatory jokes and language.

- Posting or displaying sexually explicit or violent material.
- Posting or threatening to post other people's personally identifying information ("doxing").
- Personal insults, particularly those related to gender, sexual orientation, race, religion, or disability.
- Inappropriate photography or recording.
- Inappropriate physical contact. You should have someone's consent before touching them in any manner.
- Unwelcome sexual attention. This includes sexualized comments or jokes; inappropriate touching, groping, and unwelcome sexual advances.
- Deliberate intimidation, stalking or following (online or in person).
- Advocating for, or encouraging, any of the above behavior.
- Repeated harassment of others. In general, if someone asks you to stop, then stop.
- Other conduct which could reasonably be considered inappropriate in a professional setting.

Weapons Policy

No weapons will be allowed at Tellius, Inc. events, office locations, or in other spaces covered by the scope of this Code of Conduct. Weapons include but are not limited to guns, explosives (including fireworks), and large knives such as those used for hunting or display, as well as any other item used for the purpose of causing injury or harm to others.

Anyone seen in possession of one of these items will be asked to leave immediately and will be subject to punitive action up to and including termination and involvement of law enforcement authorities. Tellius, Inc. staff are further expected to comply with all state and local laws on this matter.

Consequences of Unacceptable Behavior

Unacceptable behavior from any Tellius, Inc. staff, including those with decision-making authority, will not be tolerated.

Anyone asked to stop unacceptable behavior is expected to comply immediately.

If a staff member engages in unacceptable behavior, Tellius, Inc. leadership may take any action deemed appropriate, up to and including suspension or termination.

Vanta

Reporting Violations

If you are subject to or witness unacceptable behavior, or have any other concerns, please notify an appropriate member of Tellius, Inc. leadership as soon as possible.

It is a violation of this policy to retaliate against any person making a complaint of Unacceptable Behavior or against any person participating in the investigation of (including testifying as a witness to) any such allegation. Any retaliation or intimidation may be subject to punitive action up to and including termination.

Disciplinary Action

Employees who violate this policy may face disciplinary consequences in proportion to their violation. Tellius, Inc. management will determine how serious an employee's offense is and take the appropriate action

Responsibility

It is the [party responsible for the code of conduct]'s responsibility to ensure this policy is followed.

Version	Date	Description	Author	Approved by
2025	1-Feb-2025	2025 Version	Abhishek Panigrahi	Akay Khanna

Cryptography Policy

Policy Owner: VP of Engineering

Effective Date: 06/01/2021

1. Purpose

To ensure proper and effective use of cryptography to protect the confidentiality, authenticity and/or integrity of information. This policy establishes requirements for the use and protection of cryptographic keys throughout their entire lifecycle.

2. Scope

All information systems developed and/or controlled by Tellius, Inc. which store or transmit confidential data.

3. Policy

Tellius, Inc. shall evaluate the risks inherent in processing and storing data, and shall implement cryptographic controls to mitigate those risks where deemed appropriate. Where encryption is in use, strong cryptography with associated key management processes and procedures shall be implemented and documented. All encryption shall be performed in accordance with industry standards, including NIST SP 800-57.

For all personal data, Tellius, Inc. shall consider the state of the art, the costs of implementation and the nature, scope, context, and purposes of processing as well as the risk of varying likelihood and severity to the rights and freedoms of natural persons, and implement appropriate technical and organizational measures surrounding the pseudonymization and encryption of data to ensure a level of security appropriate to the risk.

For all web traffic sent over the public Internet containing confidential, the TLS v1.2 protocol or better must be utilized.

4. Key Management

Access to keys and secrets shall be tightly controlled in accordance with the Access Control Policy.

The following table includes the recommended usage for cryptographic keys:

Domain	Key Type	Algorithm	Key Length	Max Expiration
Web Certificate	Digital Signature	DSA or RSA PCKS#1	2048 bit	Up to 2 years for normal certificates, up to 10 years for root certificates.
Web Cipher	Encryption	AES	256 bit	N/A
Confidential	Encryption	AES	256 bit	1 Year
Password	Hash	Bcrypt, PBKDF2, or scrypt, ECDH	256 bit+10K Stretch	N/A
Laptop HDD	Encryption	AES	128 or 256 bit	N/A

5. Exceptions

Requests for an exception to this policy must be submitted to the VP of Engineering for approval.

6. Violations & Enforcement

Any known violations of this policy should be reported to the VP of Engineering. Violations of this policy can result in immediate withdrawal or suspension of system and network privileges and/or disciplinary action in accordance with company procedures up to and including termination of employment.

Version	Date	Description	Author	Approved by
<1.0>	<29-Apr-2020>	<First Version>	<OWNER>	<APPROVER>

Tellius Data Privacy Policy

Policy Owner: VP of Engineering

Effective Date: 01/01/2025

1. Purpose

- This policy outlines Tellius, Inc.'s commitment to protecting the privacy of personal data. It establishes the principles and procedures for collecting, using, storing, processing, and disclosing personal data in a manner that:
    - Adheres to applicable data privacy laws and regulations, including but not limited to GDPR, CCPA, and other relevant privacy laws.
    - Respects the privacy rights of individuals.
    - Ensures the confidentiality and security of personal data.
    - Maintains transparency in our data handling practices.
    - Meets the requirements of the AICPA's Trust Services Criteria for SOC 2, particularly those related to confidentiality.

2. Scope

- This policy applies to all Tellius personnel, contractors, and third-party service providers who collect, use, store, process, or disclose personal data on behalf of Tellius. It covers all personal data, regardless of the format (electronic or paper) or location.

3. Policy Statements

- **Lawfulness, Fairness, and Transparency:** Tellius processes personal data lawfully, fairly, and transparently. Individuals are informed about how their data is collected and used.
- **Purpose Limitation:** Personal data is collected and processed only for specified, explicit, and legitimate purposes.
- **Data Minimization:** Tellius collects only the minimum amount of personal data necessary to achieve the specified purposes.
- **Accuracy:** Tellius maintains accurate and up-to-date personal data. Procedures are in place to allow individuals to rectify inaccurate data.
- **Storage Limitation:** Personal data is stored only for as long as necessary to fulfill the specified purposes, or as required by law.
- **Integrity and Confidentiality:** Personal data is processed in a manner that ensures its security, integrity, and confidentiality, including protection against unauthorized access, use, or disclosure.
- **Accountability:** Tellius demonstrates accountability for its data processing activities and maintains appropriate records.
- **Data Subject Rights:** Tellius respects and facilitates the exercise of individuals' rights regarding their personal data, including rights of access, rectification, erasure, restriction of processing, and data portability.

4. Data Classification

To help Tellius, Inc. and its employees easily understand requirements associated with different kinds of information, the company has created three classes of data.

- **Confidential**

Highly sensitive data requiring the highest levels of protection; access is restricted to specific employees or departments, and these records can only be passed to others with approval from the data owner, or a company executive. Example include:

- Customer Data
- Personally identifiable information (PII)
- Company financial and banking data
- Salary, compensation and payroll information
- Strategic plans
- Incident reports
- Risk assessment reports
- Technical vulnerability reports
- Authentication credentials
- Secrets and private keys
- Source code
- Litigation data

- **Restricted**

  Tellius, Inc. proprietary information requiring thorough protection; access is restricted to employees with a "need-to-know" based on business requirements. This data can only be distributed outside the company with approval. This is default for all company information unless stated otherwise. Examples include:

  - Internal policies
  - Legal documents
  - Meeting minutes and internal presentations
  - Contracts
  - Internal reports
  - Slack messages
  - Email

- **Public**

  Documents intended for public consumption which can be freely distributed outside Tellius, Inc. Examples include:

  - Marketing materials
  - Product descriptions
  - Release notes
  - External facing policies

5. Procedures

- **Data Collection**
  - **Consent:** Personal data is collected with the explicit consent of the individual, where required by law. Consent requests are clear, specific, and easy to withdraw.
  - **Notice:** Individuals are provided with a clear and comprehensive privacy notice that explains:

        - The purposes of data processing
        - The types of data collected
        - The legal basis for processing
        - Data recipients
        - Data retention periods
        - Data subject rights
        - Contact information for the Data Protection Officer (DPO), if applicable
    - **Data Minimization:** Data collection is limited to what is relevant and necessary for the specified purposes.
- **Data Use**
    - **Purpose Limitation:** Personal data is used only for the purposes disclosed in the privacy notice. New purposes require obtaining new consent or ensuring compatibility with the original purpose.
    - **Data Processing Agreements:** When using third-party processors, Tellius enters into data processing agreements that ensure the processor complies with applicable data privacy laws and this policy.
    - **Internal Access:** Access to personal data within Tellius is restricted to personnel with a legitimate business need to know, based on the principle of least privilege.
- **Data Storage**
    - **Security Measures:** Personal data is stored securely, using appropriate technical and organizational measures to protect against unauthorized access, use, or disclosure. These measures include:
        - Encryption at rest and in transit
        - Access controls
        - Secure data centers
        - Regular security assessments
    - **Data Retention:** Personal data is retained only for as long as necessary to fulfill the specified purposes, or as required by law. Data retention schedules are established and enforced.
    - **Data Disposal:** When personal data is no longer needed, it is securely disposed of using approved methods to prevent unauthorized access.
- **Data Disclosure**
    - **Third-Party Sharing:** Personal data is shared with third parties only when:
        - The individual has provided consent.
        - It is necessary to fulfill a contract with the individual.
        - It is required by law.
        - It is necessary to protect the vital interests of the individual or another person.
        - It is in the public interest.
    - **International Data Transfers:** When transferring personal data to countries outside the individual's country of residence, Tellius ensures that appropriate safeguards are in place, such as:
        - Adequacy decisions from the European Commission
        - Standard contractual clauses
        - Binding corporate rules
        - Other legally approved mechanisms
    - **Transparency:** Individuals are informed about any third-party recipients of their personal data.
- **Data Subject Rights**
    - **Access:** Individuals have the right to access their personal data held by Tellius. Access requests are processed in a timely manner.
    - **Rectification:** Individuals have the right to request that inaccurate personal data be corrected.
    - **Erasure:** Individuals have the right to request the erasure of their personal data under certain circumstances (e.g., when the data is no longer necessary for the original

purpose).
    - **Restriction of Processing:** Individuals have the right to request the restriction of processing of their personal data under certain circumstances (e.g., when the accuracy of the data is contested).
    - **Data Portability:** Individuals have the right to receive their personal data in a structured, commonly used, and machine-readable format and to transmit that data to another controller.
    - **Objection:** Individuals have the right to object to the processing of their personal data under certain circumstances.
    - **Complaint:** Individuals have the right to lodge a complaint with the appropriate supervisory authority.
    - **Procedure:** Tellius has established procedures for responding to and facilitating the exercise of these rights.

6. Data Handling

- **Confidential Data Handling**

  Confidential data is subject to the following protection and handling requirements:

  - Access for non-pre approved-roles requires documented approval from the data owner
  - Access is restricted to specific employees, roles and/or departments
  - Confidential systems shall not allow unauthenticated or anonymous access
  - Confidential Customer Data shall not be used or stored in non-production systems/environments
  - Confidential data shall be encrypted in transit over public networks
  - Mobile device hard drives containing confidential data, including laptops, shall be encrypted
  - Mobile devices storing or accessing confidential data shall be protected by a log-on password or passcode and shall be configured to lock the screen after five (5) minutes of non-use
  - Backups shall be encrypted
  - Confidential data shall not be stored on personal phones or devices or removable media including USB drives, CD's, or DVD's
  - Paper records shall be labeled "confidential" and securely stored and disposed
  - Hard drives and mobile devices used to store confidential information must be securely wiped prior to disposal or physically destroyed

  - Transfer of confidential data to people or entities outside the company shall only be done in accordance with a legal contract or arrangement, and the explicit written permission of management or the data owner

- **Restricted Data Handling**

  Restricted data is subject to the following protection and handling requirements:

  - Access is restricted to users with a need-to-know based on business requirements
  - Restricted systems shall not allow unauthenticated or anonymous access
  - Transfer of restricted data to people or entities outside the company or authorized users shall require management approval and shall only be done in accordance with a legal contract or arrangement, or the permission of the data owner
  - Paper records shall be securely stored and disposed

    - Hard drives and mobile devices used to store restricted information must be securely wiped prior to disposal or physically destroyed

- **Public Data Handling**

  No special protection or handling controls are required for public data. Public data may be freely distributed.

7. Roles and Responsibilities

- **Data Protection Officer (DPO):**
  - Oversees Tellius's data privacy program and ensures compliance with applicable laws and this policy.
  - Provides guidance and training on data privacy matters.
  - Handles data subject requests and inquiries.
  - Acts as a point of contact for supervisory authorities.
- **All Personnel:**
  - Responsible for complying with this policy and applicable data privacy laws when handling personal data.
  - Completing required privacy training.
  - Reporting any suspected privacy violations.
- **Department Heads:**
  - Ensure that data processing activities within their departments comply with this policy.
  - Implement appropriate safeguards to protect personal data.
  - Provide training to their staff on data privacy requirements.
- **IT Department:**
  - Implement and maintain technical safeguards to protect personal data.
  - Ensure that systems and applications are designed to support data privacy principles.
  - Assist with data subject access requests.

8. Compliance

- **8.1 Policy Compliance:** All Tellius personnel and third parties are required to comply with this policy.
- **8.2 Non-Compliance:** Non-compliance with this policy may result in disciplinary action, up to and including termination of employment or contracts, and potential legal consequences.
- **8.3 Policy Review:** This policy will be reviewed and updated at least annually or as needed to reflect changes in data privacy laws, regulations, and business practices.

Human Resource Security Policy

Policy Owner: Colin Raaberg, Chief of Staff

Effective Date: 01/01/2025

Purpose

To ensure that employees and contractors meet security requirements, understand their responsibilities, and are suitable for their roles.

Scope

This policy applies to all employees of Tellius, Inc., consultants, contractors and other third-party entities with access to Tellius, Inc. production networks and system resources.

Policy

Competence & Performance Assessment

The skills and competence of employees and contractors shall be assessed by human resources staff and the hiring manager or his or her designees as part of the hiring process. Required skills and competencies shall be listed in job descriptions and requisitions, and/or aligned with the responsibilities outlined in the Information Security Roles and Responsibilities Policy. Competency evaluations may include reference checks, education and certification verifications, technical testing, and interviews.

All Tellius, Inc. employees will undergo an annual performance review which will include an assessment of job performance, competence in the role, adherence to company policies and code of conduct, and achievement of role-specific objectives.

Terms & Conditions of Employment

Company policies and information security roles and responsibilities shall be communicated to employees and third-parties at the time of hire or engagement, and employees and contractors are required to formally acknowledge their understanding and acceptance of their security responsibilities. Employees and third-parties with access to company or customer information shall sign an appropriate non-disclosure, confidentiality, and appropriate code-of-conduct agreements. Contractual agreements shall state responsibilities for information security as needed. Employees and relevant third-parties shall follow all Tellius, Inc. information security policies.

Management Responsibilities

Management shall be responsible for ensuring that information security policies and procedures are reviewed annually, distributed and available, and that employees and contractors abide by those policies and procedures for the duration of their employment or engagement. Annual policy review shall include a review of any linked or referenced procedures, standards or guidelines.

Management shall ensure that information security responsibilities are communicated to individuals, through written job descriptions, policies or some other documented method which is accurately updated and maintained. Compliance with information security policies and procedures and fulfillment of information security responsibilities shall be evaluated as part of the performance review process wherever applicable.

Management shall consider excessive pressures, and opportunities for fraud when establishing incentives and segregating roles, responsibilities, and authorities.

Information Security Awareness, Education & Training

All Tellius, Inc. employees and third-parties with administrative or privileged technical access to Tellius, Inc. production systems and networks shall complete security awareness training at the time of hire and annually thereafter. Management shall monitor training completion and shall take appropriate steps to ensure compliance with this policy. Employees and contractors shall be aware of relevant information security and data privacy policies and procedures. The company shall ensure that personnel receive security and data privacy training appropriate to their role and data handling responsibilities[1].

In order to maintain a robust level of security awareness, the company will provide security-related updates and communications to company personnel on an on-going basis through multiple communication channels as needed.

Information security leaders and managers shall ensure appropriate professional development occurs to provide an understanding of current threats and trends in the security landscape. Security leaders and key stakeholders shall attend trainings, obtain and maintain relevant certifications, and maintain memberships in industry groups as appropriate.

Termination Process[2]

Employee and contractor termination and offboarding processes shall ensure that physical and logical access is promptly revoked in accordance with company SLAs and policies, and that all company issued equipment is returned.

Any security or confidentiality agreements which remain valid after termination shall be communicated to the employee or contractor at time of termination.

[1] Training appropriate to roles added for v2

[2] Termination process added for v2

Disciplinary Process

Employees and third-parties who violate Tellius, Inc. information security policies shall be subject to the Tellius, Inc. progressive disciplinary process, up to and including termination of employment or contract.

Exceptions

Requests for an exception to this policy must be submitted to the VP of Strategy & Operations, Abhishek Panigrahi, for approval.

Violations & Enforcement

Any known violations of this policy should be reported to the VP of Strategy & Operations, Abhishek Panigrahi. Violations of this policy can result in immediate withdrawal or suspension of system and network privileges and/or disciplinary action in accordance with company policies up to and including termination of employment.

Version	Date	Description	Author	Approved by
2025	1-Feb-2025	2025 Version	Abhishek Panigrahi	Ajay Khanna
2025	22-Dec-2025	2025.01 Version	Jimena Bedoya	Ajay Khanna

Tellius Incident Management Policy and Procedure

Policy Owner: VP of Engineering

Effective Date: 01/01/2025

1. Purpose

- This policy establishes a framework for managing security incidents that may affect the confidentiality, integrity, or availability of Tellius's information assets and systems. It ensures that incidents are:
  - Promptly identified.
  - Effectively contained.
  - Thoroughly investigated.
  - Appropriately eradicated.
  - Recovered from in a timely manner.
  - Documented and analyzed to prevent recurrence.
- This policy aims to minimize the impact of security incidents, protect Tellius's reputation, and comply with legal, regulatory, and contractual obligations, including the AICPA's Trust Services Criteria for SOC 2.

2. Scope

- This policy applies to all Tellius personnel, contractors, and third-party service providers who use or have access to Tellius information systems and assets. It covers all types of security incidents, including but not limited to:
  - Unauthorized access to systems or data
  - Data breaches or leaks
  - Malware infections
  - Denial-of-service attacks
  - Phishing attacks
  - Insider threats
  - Physical security breaches
  - Loss or theft of company devices containing sensitive information

3. Policy Statements

- **Incident Identification:** Tellius identifies and classifies security incidents through proactive monitoring, user reporting, and other detection mechanisms.
- **Incident Response Plan:** A comprehensive Incident Response Plan (IRP) is maintained and regularly tested to provide a structured approach to managing security incidents.
- **Incident Response Team:** A designated Incident Response Team (IRT) is responsible for coordinating and executing the incident response process.
- **Containment, Eradication, and Recovery:** Incidents are contained, eradicated, and systems are recovered in a timely manner to minimize damage and disruption.
- **Incident Documentation and Reporting:** All security incidents are thoroughly documented, and significant incidents are reported to relevant stakeholders, including regulatory bodies if required.

- **Post-Incident Analysis:** A post-incident analysis is conducted for all significant incidents to determine the root cause, identify areas for improvement, and prevent recurrence.
- **Legal and Regulatory Compliance:** Incident management activities comply with all applicable legal, regulatory, and contractual requirements.

4. Procedures

- **Incident Identification**
  - **Monitoring and Detection:**
    - Tellius employs security monitoring tools and techniques to detect potential security incidents. These include, but are not limited to:
      - Security Information and Event Management (SIEM) systems
      - Intrusion Detection/Prevention Systems (IDS/IPS)
      - Log analysis
      - Vulnerability scanning
    - System and application logs are regularly reviewed for suspicious activity.
  - **User Reporting:**
    - All Tellius personnel are required to report any suspected security incidents or vulnerabilities immediately to the Security Team or designated contact.
    - Clear reporting mechanisms, such as a dedicated email address or hotline, are provided.
  - **Third-Party Reporting:**
    - Procedures are established for receiving and processing security incident reports from external parties, such as customers, vendors, and security researchers.
- **Incident Response Plan (IRP)**
  - **IRP Development and Maintenance:**
    - The IRP is developed, maintained, and regularly updated by the Security Team.
    - The IRP includes detailed procedures for each phase of the incident response lifecycle.
  - **IRP Testing:**
    - The IRP is tested regularly through simulations, tabletop exercises, or full-scale exercises to ensure its effectiveness and identify areas for improvement.
    - Testing results are documented, and the IRP is updated as needed.
  - **IRP Communication:**
    - The IRP is communicated to all relevant personnel, and their roles and responsibilities are clearly defined.
- **Incident Response Team (IRT)**
  - **IRT Composition:**
    - The IRT comprises individuals with the necessary skills and expertise to handle security incidents, including:
      - Security analysts
      - System administrators
      - Network engineers
      - Legal counsel
      - Public relations
      - Management representatives
  - **IRT Roles and Responsibilities:**
    - The IRT has clearly defined roles and responsibilities, including:
      - Incident lead
      - Containment specialist
      - Forensics analyst
      - Communications officer
  - **IRT Communication:**

        - The IRT has established communication channels and procedures for internal and external stakeholders.
- **Containment, Eradication, and Recovery**
    - **Containment:**
        - Incidents are contained to prevent further damage and limit their scope. Containment measures may include:
            - Isolating affected systems or networks
            - Blocking malicious traffic
            - Taking systems offline
        - The containment strategy is documented.
    - **Eradication:**
        - The root cause of the incident is identified and eliminated to prevent recurrence. Eradication may involve:
            - Removing malware
            - Patching vulnerabilities
            - Correcting misconfigurations
        - Eradication steps are documented.
    - **Recovery:**
        - Affected systems and data are recovered to normal operations as quickly and securely as possible. Recovery procedures may include:
            - Restoring from backups
            - Rebuilding systems
            - Data recovery
        - The recovery process is documented.
- **Incident Documentation and Reporting**
    - **Incident Documentation:**
        - All security incidents are documented in a centralized incident management system. Documentation includes:
            - Date and time of the incident
            - Description of the incident
            - Affected systems and data
            - Incident severity and priority
            - Actions taken for containment, eradication, and recovery
            - Root cause analysis
            - Lessons learned
        - Evidence related to the incident is preserved.
    - **Internal Reporting:**
        - Incident reports are provided to relevant internal stakeholders, including:
            - Management
            - Legal counsel
            - Affected system owners
    - **External Reporting:**
        - Significant security incidents are reported to external parties as required by law, regulation, or contract. This may include:
            - Customers
            - Law enforcement
            - Regulatory agencies
            - Data protection authorities
- **Post-Incident Analysis**
    - **Analysis:**
        - A post-incident analysis is conducted for all significant incidents to determine the underlying causes and contributing factors.
    - **Corrective Actions:**

        - Corrective actions are identified and implemented to prevent similar incidents from occurring in the future. These actions may include:
            - Improving security controls
            - Enhancing monitoring and detection capabilities
            - Providing additional security training
            - Modifying policies and procedures
    - **Documentation:**
        - The post-incident analysis findings and corrective actions are documented.

5. Roles and Responsibilities

- **All Personnel:**
    - Responsible for reporting suspected security incidents immediately.
- **Incident Response Team (IRT):**
    - Responsible for managing and coordinating the response to security incidents according to the IRP.
    - Conducting incident analysis and investigations.
    - Implementing containment, eradication, and recovery measures.
    - Communicating with stakeholders.
    - Documenting incident details.
- **Security Team:**
    - Developing and maintaining the IRP.
    - Providing guidance and support to the IRT.
    - Conducting post-incident analysis.
    - Implementing corrective actions.
    - Ensuring compliance with legal and regulatory requirements.
- **IT Operations:**
    - Assisting the IRT with technical aspects of incident response, such as system isolation and recovery.
    - Implementing security controls and configurations to prevent incidents.
    - Providing system logs and other relevant data.
- **Legal Counsel:**
    - Providing legal advice on incident response activities and reporting requirements.
    - Liaising with law enforcement and regulatory agencies as needed.
- **Management:**
    - Providing resources and support for incident management activities.
    - Ensuring that the incident response plan is regularly tested and updated.
    - Ensuring compliance with this policy.

6. Compliance

- **6.1 Policy Compliance:** All Tellius personnel and third parties are required to comply with this policy.
- **6.2 Non-Compliance:** Non-compliance with this policy may result in disciplinary action, up to and including termination of employment or contracts, and potential legal consequences.
- **6.3 Policy Review:** This policy and the associated IRP will be reviewed and updated at least annually or as needed to reflect changes in technology, threats, and business requirements.

7. Other Related Policies and Procedures

-
    - Security Policy

- Data Breach Notification Policy
- Business Continuity Plan
- Disaster Recovery Plan
- System and Network Configuration Standards
- Vulnerability Management Policy

Information Security Policy

Policy Owner: VP of Engineering

Effective Date: 01/01/2025

Overview

This Information Security Policy is intended to protect Tellius, Inc.'s employees, partners and the company from illegal or damaging actions by individuals, either knowingly or unknowingly.

Internet/Intranet/Extranet-related systems, including but not limited to computer equipment, software, operating systems, storage media, network accounts providing electronic mail, web browsing, and file transfers, are the property of Tellius, Inc.. These systems are to be used for business purposes in serving the interests of the company, and of our clients and customers in the course of normal operations.

Effective security is a team effort involving the participation and support of every Tellius, Inc. employee or contractor who deals with information and/or information systems. It is the responsibility of every team member to read and understand this policy, and to conduct their activities accordingly.

Purpose

The purpose of this policy is to communicate our information security policies and outline the acceptable use and protection of Tellius, Inc.'s information and assets. These rules are in place to protect customers, employees, and Tellius, Inc.. Inappropriate use exposes Tellius, Inc. to risks including virus attacks, compromise of network systems and services, and legal and compliance issues.

The Tellius, Inc. "Information Security Policy" is comprised of this policy and all Tellius, Inc. policies referenced and/or linked within this document.

Scope

This policy applies to the use of information, electronic and computing devices, and network resources to conduct Tellius, Inc. business or interact with internal networks and business systems, whether owned or leased by Tellius, Inc., the employee, or a third party. All employees, contractors, consultants, temporary, and other workers at Tellius, Inc. and its subsidiaries are responsible for exercising good judgment regarding appropriate use of information, electronic devices, and network resources in accordance with Tellius, Inc. policies and standards, and local laws and regulations.

This policy applies to employees, contractors, consultants, temporaries, and other workers at Tellius, Inc., including all personnel affiliated with third parties. This policy applies to all Tellius, Inc.-controlled company and customer data as well as all equipment, systems, networks and software owned or leased by Tellius, Inc..

Security Incident Reporting

All users are required to report known or suspected security events or incidents, including policy violations and observed security weaknesses. Incidents should be reported immediately or as soon

as possible by email to hroperations@tellius.com. In your email please describe the incident or observation along with any relevant details.

Mobile Device Policy

Tellius Inc. enforces this policy on all end-user devices, including mobile phones, tablets, laptops, and desktops, used to access company information systems. The following security standards are in place to govern the use of these devices, whether company-owned or personally owned (BYOD):

- **Email Security:** Users are required to exercise extreme caution when opening email attachments, especially those from unknown or untrusted senders, as these may contain malware. Tellius security systems and user training emphasize this requirement.
- **Password Protection:** All system-level and user-level passwords must comply with the Tellius Access Control Policy. Sharing of login credentials or failure to secure device access is strictly prohibited and actively prevented through technical controls and user agreements.
- **Device Security Requirements:** All devices used to access Tellius, Inc. information systems, including company email, adhere to the following security standards:
- **Device Encryption:** Devices must be encrypted with a password-protected screensaver or screen lock. This is enforced through device configuration policies.
- **Device Lockout:** Devices are configured to lock automatically whenever left unattended.
- **Incident Reporting:** Users are required to immediately report any suspected misuse or theft of a mobile device to the Operations Director. This reporting process is communicated to all users.
- **Data Storage:** Storage of confidential information on mobile devices or USB drives is prohibited. Technical controls and user agreements enforce this restriction. Basic business contact information, such as names, phone numbers, and email addresses, is exempt from this restriction.
- **Device Sharing:** Sharing of any mobile device used to access company email with any other person is strictly prohibited and actively prevented.
- **Termination Procedures:** Upon termination of employment or a contract, the following procedures are enforced:

1. Return of Devices: Users must return all company-owned devices.

2. Data Removal: Users are required to remove all company information and accounts from any personal devices. Acknowledgement of this requirement is obtained during the off-boarding process.

Remote Access Policy

Laptops and other computer resources that are used to access the Tellius, Inc. network must conform to the security requirements outlined in Tellius, Inc.'s Information Security Policies and adhere to the following standards:

- To ensure mobile devices do not connect a compromised device to the company network, Antivirus policies require the use and enforcement of client-side antivirus software
- Users are prohibited from changing or disabling any organizational security controls such as personal firewalls, antivirus software on systems used to access Tellius, Inc. resources
- Use of remote access software and/or services (e.g., VPN client) is allowable as long as it is provided by the company and configured for multifactor authentication (MFA)
- Unauthorized remote access technologies may not be used or installed on any Tellius, Inc. system
- Whenever possible users should use a VPN when transmitting confidential information on public Wi-Fi

- If you access from a public computer (e.g., business center, hotel, etc.), log out of session and don't save anything. Don't check "remember me, collect all printed materials and delete downloaded files (generally is discouraged)

Removable Media and Portable Storage Devices

The company prohibits the use of removable media (e.g., USB drives, external hard drives, SD cards, or other portable storage devices) for storing or transferring company data, unless explicitly authorized by the Information Security team.

Encryption Requirement: Any authorized use of removable media must ensure that the device is fully encrypted using company-approved encryption standards.

Blocking Policy: By default, company-managed devices are configured to block or restrict the use of removable media to prevent unauthorized data transfer.

Exceptions: In rare cases where removable media use is required for business purposes, prior written approval from the Information Security team must be obtained, and encryption must be enforced.

User Responsibility: Employees must not copy, transfer, or store company data on personal or unencrypted removable media devices under any circumstances.

Monitoring and Enforcement: The company reserves the right to monitor device usage and enforce technical controls to prevent unauthorized use of removable media. Violations of this policy may result in disciplinary action, up to and including termination.

Acceptable Use Policy

Tellius, Inc. proprietary and customer information stored on electronic and computing devices whether owned or leased by Tellius, Inc., the employee or a third party, remains the sole property of Tellius, Inc. for the purposes of this policy. Employees and contractors must ensure through legal or technical means that proprietary information is protected in accordance with the Data Management Policy. The use of <company file sharing system, e.g., Google Drive> for business file storage is required for users of laptops or company issued devices. Storing important documents on the file share is how you "backup" your laptop.

You have a responsibility to promptly report the theft, loss, or unauthorized disclosure of Tellius, Inc. proprietary information. You may access, use or share Tellius, Inc. proprietary information only to the extent it is authorized and necessary to fulfill your assigned job duties. Employees are responsible for exercising good judgment regarding the reasonableness of personal use of company-provided devices.

For security and network maintenance purposes, authorized individuals within Tellius, Inc. may monitor equipment, systems and network traffic at any time.

Tellius, Inc. reserves the right to audit networks and systems on a periodic basis to ensure compliance with this policy.

Unacceptable Use

The following activities are, in general, prohibited. Employees may be exempted from these restrictions during the course of their legitimate job responsibilities. Under no circumstances is an employee of Tellius, Inc. authorized to engage in any activity that is illegal under local, state, federal

or international law while utilizing Tellius, Inc.-owned resources. The list below is not exhaustive, but attempts to provide a framework for activities which fall into the category of unacceptable use.

The following activities are strictly prohibited, with no exceptions:

1. Violations of the rights of any person or company protected by copyright, trade secret, patent, or other intellectual property, or similar laws or regulations, including, but not limited to, the installation or distribution of "pirated" or other software products that are not appropriately licensed for use by Tellius, Inc..
2. Unauthorized copying of copyrighted material including, but not limited to, digitization and distribution of photographs from magazines, books, or other copyrighted sources, copyrighted music, and the installation of any copyrighted software for which Tellius, Inc. or the end user does not have an active license.
3. Accessing data, a server, or an account for any purpose other than conducting Tellius, Inc. business, even if you have authorized access, is prohibited.
4. Exporting software, technical information, encryption software, or technology, in violation of international or regional export control laws, is illegal. The appropriate management should be consulted prior to export of any material that is in question.
5. Introduction of malicious programs into the network or systems (e.g., viruses, worms, Trojan horses, e-mail bombs, etc.).
6. Revealing your account password to others or allowing use of your account by others. This includes family and other household members when work is being done at home.
7. Using a Tellius, Inc. computing asset to actively engage in procuring or transmitting material that is in violation of sexual harassment or hostile workplace laws.
8. Making fraudulent offers of products, items, or services originating from any Tellius, Inc. account.
9. Making statements about warranty, expressly or implied, unless it is a part of normal job duties.
10. Effecting security breaches or disruptions of network communication. Security breaches include, but are not limited to, accessing data of which the employee is not an intended recipient, or logging into a server or account that the employee is not expressly authorized to access, unless these duties are within the scope of regular duties. For purposes of this section, "disruption" includes, but is not limited to, network sniffing, pinged floods, packet spoofing, denial of service, and forged routing information for malicious purposes.
11. Port scanning or security scanning is expressly prohibited unless prior notification to the Tellius, Inc. engineering team is made.
12. Executing any form of network monitoring which will intercept data not intended for the employee's host, unless this activity is a part of the employee's normal job/duty.
13. Circumventing user authentication or security of any host, network, or account.
14. Introducing honeypots, honeynets, or similar technology on the Tellius, Inc. network.
15. Interfering with or denying service to any user other than the employee's host (for example, denial of service attack).
16. Using any program/script/command, or sending messages of any kind, with the intent to interfere with, or disable, a user's session, via any means.
17. Providing information about, or lists of: Tellius, Inc. employees, contractors, partners, or customers to parties outside Tellius, Inc. without authorization.

Email and Communication Activities

When using company resources to access and use the Internet, users must realize they represent the company and act accordingly.

The following activities are strictly prohibited, with no exceptions:

1. Sending unsolicited email messages, including the sending of "junk mail", or other advertising material to individuals who did not specifically request such material (email spam).

2. Any form of harassment via email, telephone, or texting, whether through language, frequency, or size of messages.
3. Unauthorized use, or forging, of email header information.
4. Solicitation of email for any other email address, other than that of the poster's account, with the intent to harass or to collect replies.
5. Creating or forwarding "chain letters", "Ponzi", or other "pyramid" schemes of any type.
6. Use of unsolicited email originating from within Tellius, Inc. networks or other service providers on behalf of, or to advertise, any service hosted by Tellius, Inc. or connected via Tellius, Inc.'s network.

Additional Policies and Procedures Incorporated by Reference

Role	Purpose
Access Control Policy	To limit access to information and information processing systems, networks, and facilities to authorized parties in accordance with business objectives.
Asset Management Policy	To identify organizational assets and define appropriate protection responsibilities.
Business Continuity & Disaster Recovery Plan	To prepare Tellius, Inc. in the event of extended service outages caused by factors beyond our control (e.g., natural disasters, man-made events), and to restore services to the widest extent possible in a minimum time frame.
Cryptography Policy	To ensure proper and effective use of cryptography to protect the confidentiality, authenticity and/or integrity of information.
Data Management Policy	To ensure that information is classified and protected in accordance with its importance to the organization.
Human Resources Policy	To ensure that employees and contractors meet security requirements, understand their responsibilities, and are suitable for their roles.
Incident Response Plan	Policy and procedures for suspected or confirmed information security incidents.
Operations Security Policy	To ensure the correct and secure operation of information processing systems and facilities.
Physical Security Policy	To prevent unauthorized physical access or damage to the organization's information and information processing facilities.
Risk Management Policy	To define the process for assessing and managing Tellius, Inc.'s information security risks in order to achieve the company's business and information security objectives.
Secure Development Policy	To ensure that information security is designed and implemented within the development lifecycle for applications and information systems.
Third-Party Management Policy	To ensure protection of the organization's data and assets that are shared with, accessible to, or managed by suppliers, including external parties or third-party organizations such as service providers, vendors, and customers, and to maintain an agreed level of information security and service delivery in line with supplier agreements.

Policy Compliance

Tellius, Inc. will measure and verify compliance to this policy through various methods, including but not limited to, business tool reports or internal audits.

Exceptions

Requests for an exception to this policy must be submitted to the Policy Owner for approval.

Violations & Enforcement

Any known violations of this policy should be reported to the Policy Owner Violations of this policy can result in immediate withdrawal or suspension of system and network privileges and/or disciplinary action in accordance with company procedures up to and including termination of employment.

Version	Date	Description	Author	Approved by
1.0	29-Apr-2020	First Version	Radu Miclaus	Ajay Khanna
2.0	01-01-2025			

Vanta

Information Security Roles and Responsibilities Policy

Policy Owner: VP of Engineering

Effective Date: 06/01/2021

Statement of Policy

Tellius, Inc. is committed to conducting business in compliance with all applicable laws, regulations, and company policies. Tellius, Inc. has adopted this policy to outline the security measures required to protect electronic information systems and related equipment from unauthorized use.

Objective

This policy and associated guidance establish the roles and responsibilities within Tellius, Inc., which is critical for effective communication of information security policies and standards. Roles are required within the organization to provide clearly defined responsibilities and an understanding of how the protection of information is to be accomplished. Their purpose is to clarify, coordinate activity, and actions necessary to disseminate security policy, standards, and implementation.

Applicability

This policy is applicable to all Tellius, Inc. infrastructure, network segments, and systems.

Audience

The audience for this policy includes all Tellius, Inc. employees and contractors who are involved with the Information Security Program. Awareness of this policy applies for all other agents of Tellius, Inc. with access to Tellius, Inc. information and network. This includes, but not limited to partners, affiliates, contractors, temporary employees, trainees, guests, and volunteers. The titles will be referred collectively hereafter as "Tellius, Inc. community".

Roles	Responsibilities
Board of Directors	• Oversight over Cyber-Risk and internal control for information security, privacy and compliance

Vanta

	• Consults with Executive Leadership to understand Tellius, Inc. IT mission and risks and provides guidance to bring them into alignment
Executive Leadership	• Approves Capital Expenditures for Information Security • Oversight over the execution of the information security risk management program and risk treatments • Communication Path to Tellius, Inc. Board of Directors • Aligns Information Security Policy and Posture based on Tellius, Inc.'s mission, strategic objectives and risk appetite
VP of Engineering	• Oversight over information security in the software development process • Responsible for the design, development, implementation, operation, maintenance and monitoring of development and commercial cloud hosting security controls • Responsible for oversight over policy development • Responsible for implementing risk management in the development process
Systems Owners	• Manage the confidentiality, integrity and availability of the information systems for which they are responsible in compliance with Tellius, Inc. policies on information security and privacy. • Approval of technical access and change requests for non-standard access
Tellius, Inc. Employees, Contractors, temporary workers, etc.	• Acting at all times in a manner which does not place at risk the health and safety of themselves, other person in the workplace, and the information and resources they have use of • Helping to identify areas where risk management practices should be adopted • Taking all practical steps to minimize Tellius, Inc.'s exposure to contractual and regulatory liability • Adhering to company policies and standards of conduct • Reporting incidents and observed anomalies or weaknesses
Operations Lead	• Ensuring employees and contractors are qualified and competent for their roles • Ensuring appropriate testing and background checks are completed • Ensuring that employees and relevant contractors are presented with company policies and the Code of Conduct (CoC) • Ensuring that employee performance and adherence the CoC is periodically evaluated

	• Ensuring that employees receive appropriate security training

Policy Compliance

The Policy Owner will measure the compliance to this policy through various methods, including, but not limited to—reports, internal/external audits, and feedback to the policy owner. Exceptions to the policy must be approved by the Policy Owner in advance. Non-compliance will be addressed with management and Human Resources and can result in disciplinary action in accordance with company procedures up to and including termination of employment.

Version	Date	Description	Author	Approved by
<1.0>	<29-Apr-2020>	<First Version>	<OWNER>	<APPROVER>

Operations Security Policy

Policy Owner: Operations Lead

Effective Date: 02/01/2023

1. **Purpose**

To ensure the correct and secure operation of information processing systems and facilities.

1. **Scope**

All Tellius, Inc. information systems that are business critical and/or process, store, or transmit company data. This Policy applies to all employees of Tellius, Inc. and other third-party entities with access to Tellius, Inc. networks and system resources.

1. **Operations Security**

Documented Operating Procedures

Operating procedures shall be documented and made available to all users who need them via GDrive documents or Notion

Change Management

Changes to the organization, business processes, information processing facilities, and systems that affect information security in the production environment and financial systems shall be controlled. All significant changes to in-scope systems must be documented.

Change management processes shall include: [Change Management Process]

- Processes for planning and testing of changes, including remediation measures
- Documented managerial approval and authorization before proceeding with changes that may have a significant impact on information security, operations, or the production platform
- Advance communication/warning of changes, including schedules and a description of reasonably anticipated effects, provided to all relevant internal and external stakeholders
- Documentation of all emergency changes and subsequent review
- A process for remediating unsuccessful changes

Capacity Management

The use of processing resources and system storage shall be monitored and adjusted to ensure that system availability and performance meets Tellius, Inc. requirements.

Human resource skills, availability, and capacity shall be reviewed and considered as a component of capacity planning and as part of the annual risk assessment process.

Scaling resources for additional processing or storage capacity, without changes to the system, can be done outside of the standard change management and code deployment process.

Separation of Development, Staging and Production Environments

Development and staging environments shall be strictly segregated from production SaaS environments to reduce the risks of unauthorized access or changes to the operational environment. Confidential production customer data must not be used in development or test environments without the express approval of the Engineering Leads.

For a full description, see the Data Management Policy for a description of Confidential data. If production customer data is approved for use in the course of development or testing, it shall be scrubbed of any such sensitive information whenever feasible.

1. **Systems and Network Configuration, Hardening, and Review**

Systems and networks shall be provisioned and maintained in accordance with the configuration and hardening standards in Appendix A to this policy.

Firewalls shall be used to control network traffic to and from the production environment in accordance with this policy.

Production firewall rules shall be reviewed at least annually. Tickets shall be created to obtain approvals for any needed changes.

1. **Protection from Malware**

In order to protect the company's infrastructure against the introduction of malicious software, detection, prevention, and recovery controls to protect against malware shall be implemented, combined with appropriate user awareness.

Anti-malware protections shall be utilized on all employee issued laptops except for those running operating systems not normally prone to malicious software (example Macbooks Pro). Additionally, threat detection and response software shall be utilized for company email. The anti-malware protections utilized shall be capable of detecting all common forms of malicious threats.

Tellius, Inc. should scan all files upon their introduction to systems, and continually scan files upon access, modification, or download. Anti-malware definition updates should be configured to be downloaded and installed automatically whenever new updates are available. Known or suspected malware incidents must be reported as a security incident.

It is a violation of company policy to disable or alter the configuration of anti-malware protections without authorization.

1. **Information Backup**

The need for backups of systems, databases, information and data shall be considered and appropriate backup processes shall be designed, planned and implemented. Security measures to protect backups shall be designed and applied in accordance with the confidentiality or sensitivity of the data. Backup copies of information, software and system images shall be taken regularly to protect against loss of data. Backups and restore capabilities shall be periodically tested, not less than annually.

Tellius, Inc. does not regularly backup user devices like laptops. Users are expected to store critical files and information in company-sanctioned file storage repositories (GDrive, S3 Buckets in AWS or OneDrive).

Backups are configured to run twice daily on in-scope systems. The backup schedules are maintained within the backup application software.

1. **Logging & Monitoring**

Production infrastructure shall be configured to produce detailed logs appropriate to the function served by the system or device. Event logs recording user activities, exceptions, faults and information security events shall be produced, kept and reviewed through manual or automated processes as needed. Appropriate alerts shall be configured for events that represent a significant threat to the confidentiality, availability or integrity of production systems or Confidential data.

Protection of Log Information

Logging facilities and log information shall be protected against tampering and unauthorized access.

Administrator & Operator Logs

System administrator and system operator activities shall be logged and reviewed and/or alerted in accordance with the system classification and criticality.

Clock Synchronization

The clocks of all relevant information processing systems within an organization or security domain shall be synchronized to network time servers using reputable time sources.

1. **Control of Operational Software**

The installation of software on production systems shall follow the change management requirements defined in this policy.

1. **Technical Vulnerability Management**

Information about technical vulnerabilities of information systems being used shall be obtained in a timely fashion, the organization's exposure to such vulnerabilities shall be evaluated, and appropriate measures taken to address the associated risk. A variety of methods shall be used to obtain information about technical vulnerabilities, including vulnerability scanning, penetration tests, and the bug bounty program.

External vulnerability scans shall be run on the production environment at least quarterly. Interior vulnerability scans shall be run against test environments which mirror production configurations.

Penetration tests of the applications and production network shall be performed at least annually. Additional scanning and testing shall be performed following major changes to production systems.

The IT and Engineering departments shall evaluate the severity of vulnerabilities, and if it is determined to be a critical or high-risk vulnerability, a service ticket will be created. The Tellius, Inc. assessed severity level may differ from the level automatically generated by scanning software or determined by external researchers based on Tellius, Inc.'s internal knowledge and understanding of technical architecture and real-world impact/exploitability. Tickets are assigned to the system, application, or platform owners for further investigation and/or remediation.

Vulnerabilities assessed by Tellius, Inc. shall be remediated in the following timeframes:

Determined Severity	Remediation Time
Critical	**30 Days**
High	**30 Days**
Medium	**60 Day**
Low	**90 Days**
Informational	**As needed**

Service tickets for any vulnerability which cannot be remediated within the standard timeline must show a risk treatment plan and planned remediation timeline.

1. **Restrictions on Software Installation**

Rules governing the installation of software by users shall be established and implemented in accordance with the Tellius, Inc. Information Security Policy.

1. **Information Systems Audit Considerations**

Audit requirements and activities involving verification of operational systems shall be carefully planned and agreed to minimize disruptions to business processes.

1. **Exceptions**

Requests for an exception to this policy must be submitted to the Operations Lead for approval.

1. **Violations & Enforcement**

Any known violations of this policy should be reported to the Operations Lead. Violations of this policy can result in immediate withdrawal or suspension of system and network privileges and/or disciplinary action in accordance with company procedures up to and including termination of employment.

Version	Date	Description	Author	Approved by
1.0	29-Apr-2020	1st Version	Radu Miclaus	Ajay Khanna
2.0	01-Feb-2023	2nd Version	Deepak Sharma	Ajay Khanna

Physical Security Policy

Policy Owner: Operations Lead

Effective Date: 06/01/2021

1. Purpose

To prevent unauthorized physical access or damage to the organization's information and information processing facilities.

2. Scope

All Tellius, Inc. offices and locations. This Policy applies to all employees of Tellius, Inc., and to all external parties with physical access to Tellius, Inc. owned or leased facilities.

3. Policy

Physical Security Perimeter

Physical offices and processing facilities shall meet all local building codes for construction materials for walls, windows, doors, and access control mechanisms. Some interior zones may be identified as secure areas where physical access is further restricted to a subset of Tellius, Inc. personnel; such as private offices, wiring closets, print and server rooms, and server racks.

Physical Entry Controls

Secure areas shall be protected by appropriate entry controls to ensure that only authorized personnel are allowed access. Where possible, Tellius, Inc. access control systems shall be tied to a centralized system that provides granular access control for individual personnel. Access events shall be appropriately logged and reviewed as needed according to risk. Cameras and intrusion detection systems shall be used at facilities that store or process production data.

Securing Offices, Rooms & Facilities

Physical security for offices, rooms and facilities shall be designed and applied to protect from theft, misuse, environmental threats, unauthorized access, and other threats to the confidentiality, integrity, and availability of classified data and systems.

Protecting Against External & Environmental Threats

Physical protection against natural disasters, malicious attack or accidents shall be designed and applied. Secure areas shall be monitored through the use of intrusion detection systems, alarms, and/or video surveillance systems where feasible. Visitor and third-party access to secure areas shall be restricted to reduce the risk of information loss and theft.

Production processing facilities shall be equipped with appropriate environmental and business continuity controls including fire-suppression systems, climate control and monitoring systems, and emergency backup power systems. Physical information system hardware and supporting infrastructure shall be regularly serviced and maintained in accordance with the manufacturer's recommendations.

Working in Secure Areas / Visitor Management

Visitors, delivery personnel, outside support technicians, and other external agents shall not be permitted access to secure areas without escort and/or appropriate oversight. Third-parties in secure areas shall sign in and out on a visitor log and shall be escorted or monitored by Tellius, Inc. personnel. Tellius, Inc. personnel observing unescorted visitors should approach the visitor, confirm their status, and ensure they return to approved areas, or report the observation to the responsible authority as needed. External party access to secure areas shall be confirmed with appropriate Tellius, Inc. personnel prior to being granted access. Tellius, Inc. personnel providing access to external parties into secure areas are responsible for ensuring that the third-party personnel adhere to all security requirements, and are accountable for all actions taken by outsiders they provide with access. Visitors may be allowed to work unescorted provided that the Tellius, Inc. sponsoring party can ensure that they will not have unauthorized access to Tellius, Inc. information systems, networks, or data.

Delivery & Loading Areas

Access points such as delivery and loading areas and other points where unauthorized persons could enter secure areas shall be controlled and, if possible, isolated from information processing facilities to avoid unauthorized access.

Supplier, Vendor, and Third-Party Security

Suppliers, vendors, and third-parties shall comply with Tellius, Inc. physical security and environmental controls requirements. Tellius, Inc. shall assess the adequacy of third-party physical security controls as part of the vendor management process, in accordance with the Third-Party Management Policy.

4. Exceptions

Requests for an exception to this policy must be submitted to the Operations Lead for approval.

5. Violations & Enforcement

Any known violations of this policy should be reported to the Operations Lead. Violations of this policy can result in immediate withdrawal or suspension of system and network privileges and/or disciplinary action in accordance with company procedures up to and including termination of employment.

Version	Date	Description	Author	Approved by
<1.0>	<29-Apr-2020>	<First Version>	<OWNER>	<APPROVER>

Tellius Risk and Vulnerability Assessment Program

Policy Owner: VP of Engineering

Effective Date: 01/01/2025

1. Purpose

- This document outlines Tellius's program for managing risks and vulnerabilities related to its information systems and assets. It establishes a framework for:
  - Identifying, analyzing, and evaluating risks to Tellius's information systems.
  - Identifying, analyzing, and evaluating vulnerabilities in Tellius's information systems.
  - Implementing appropriate controls to mitigate risks and address vulnerabilities.
  - Ensuring compliance with relevant legal, regulatory, and contractual obligations, including the AICPA's Trust Services Criteria for SOC 2.

2. Scope

- This program applies to all Tellius information systems and assets, including but not limited to:
  - Applications
  - Systems
  - Networks
  - Infrastructure
  - Data
  - Hardware
  - Software
  - Facilities
  - Personnel

3. Policy Statements

- **3.1 Risk Assessments:**
  - Risk assessments are conducted regularly to identify, analyze, and evaluate potential threats and vulnerabilities to Tellius's information systems.
  - Risk assessments are performed for every release which is every 8 weeks.
  - These assessments consider the likelihood and potential impact of identified risks.
  - Risk assessments are used to prioritize and guide the implementation of security controls.
- **3.2 Vulnerability Assessments:**
  - Vulnerability assessments are conducted to identify, analyze, and evaluate technical weaknesses in Tellius's information systems.
  - These assessments employ a combination of automated and manual techniques.
  - Identified vulnerabilities are promptly reported to system owners and remediated in a timely manner.
- **3.3 Remediation:**
  - Remediation plan
    - Critical - 2 weeks
    - High - 4 weeks
    - Medium - 8 weeks
    - Low - 90 days

    - A well-defined process is in place to address identified risks and vulnerabilities.
    - Remediation activities are prioritized based on the severity of the risk or vulnerability.
    - The effectiveness of remediation activities is verified.
- **3.4 Documentation:**
    - All risk and vulnerability assessments, and remediation activities are thoroughly documented.
    - This documentation is maintained and kept up-to-date.
- **3.5 Roles and Responsibilities:**
    - Roles and responsibilities for conducting risk and vulnerability assessments, and for implementing remediation activities, are clearly defined and assigned.
- **3.6 Frequency:**
    - Risk and vulnerability assessments are performed with a frequency appropriate to the environment and business needs.

4. Procedures

- **4.1 Risk Assessment Procedures**
    - **4.1.1 Risk Identification:**
        - Identify potential threats (e.g., unauthorized access, data breach, natural disaster) and vulnerabilities (e.g., software flaws, misconfigurations) that could affect information systems.
        - Consider internal and external threats.
    - **4.1.2 Risk Analysis:**
        - Evaluate the likelihood of each threat occurring.
        - Assign vulnerabilities to relevant asset owners or teams
        - Determine the potential impact (e.g., financial loss, reputational damage, legal consequences) if the threat were to be realized.
    - **4.1.3 Risk Evaluation:**
        - Prioritize identified risks based on their likelihood and impact.
        - Use a risk matrix or other methodology to assign risk levels (e.g., high, medium, low).
    - **4.1.4 Risk Treatment:**
        - Determine appropriate risk treatment options:
            - Mitigation: Implement controls to reduce the likelihood or impact of the risk.
            - Transfer: Transfer the risk to a third party (e.g., insurance).
            - Acceptance: Accept the risk if the cost of mitigation outweighs the potential benefit.
            - Avoidance: Eliminate the risk by not engaging in the activity.
        - Document the selected risk treatment strategy.
    - **4.1.5 Documentation:**
        - Document the risk assessment process, including:
            - Scope of the assessment
            - Identified threats and vulnerabilities
            - Likelihood and impact analysis
            - Risk levels
            - Risk treatment decisions
            - Responsible parties
            - Review and approval
    - **4.1.6 Schedule:**
        - Define the schedule for risk assessments (e.g., annually, semi-annually, or more frequently based on the environment).
- **4.2 Vulnerability Assessment Procedures**
    - **4.2.1 Vulnerability Scanning:**

        - Perform regular vulnerability scans of systems, networks, and applications using automated tools.
        - Select appropriate scanning tools based on the target systems and applications.
        - Configure scanning tools to check for a wide range of vulnerabilities (e.g., CVEs).
        - Perform both authenticated and unauthenticated scans.
    - **4.2.2 Penetration Testing:**
        - Conduct periodic penetration testing (every 6 months) to simulate real-world attacks and identify exploitable vulnerabilities.
        - Use qualified and experienced penetration testers (internal or external).
        - Define the scope and rules of engagement for penetration tests.
        - Perform penetration testing on critical systems and applications.
    - **4.2.3 Manual Vulnerability Assessments:**
        - Perform manual vulnerability assessments, such as:
            - Code reviews: Reviewing source code for security flaws.
            - Configuration reviews: Checking system and application configurations for security weaknesses.
            - Security audits: Evaluating security controls and processes.
    - **4.2.4 Vulnerability Analysis:**
        - Analyze the results of vulnerability scans and penetration tests to identify true vulnerabilities and prioritize them.
        - Determine the potential impact and exploitability of each vulnerability.
    - **4.2.5 Reporting:**
        - Document and report identified vulnerabilities, including:
            - Description of the vulnerability
            - Affected systems and applications
            - Severity level (e.g., critical, high, medium, low)
            - Recommendations for remediation
    - **4.2.6 Schedule:**
        - Define the schedule for vulnerability assessments:
            - Vulnerability scanning: (e.g., weekly, monthly)
            - Penetration testing: (e.g., annually, semi-annually)
            - Manual vulnerability assessments: (e.g., as needed, triggered by significant changes)
- **4.3 Remediation Procedures**
    - **4.3.1 Vulnerability Prioritization:**
        - Prioritize vulnerabilities for remediation based on:
            - Severity level
            - Exploitability
            - Potential impact
            - Business criticality of affected systems
    - **4.3.2 Remediation Planning:**
        - Develop a remediation plan that includes:
            - Specific actions to be taken
            - Responsible parties
            - Timelines for remediation
            - Required resources
            - Testing and verification procedures
    - **4.3.3 Remediation Implementation:**
        - Implement remediation actions according to the remediation plan.
        - Apply patches, update configurations, or implement other necessary changes.
    - **4.3.4 Verification:**
        - Verify the effectiveness of remediation actions through:
            - Re-scanning with vulnerability scanning tools
            - Re-testing with penetration testing

        - Manual verification
    - **4.3.5 Exceptions:**
        - Document any exceptions to the remediation process.
        - Exceptions must be approved by appropriate authority.
    - **4.3.6 Tracking:**
        - Track the progress of remediation activities.
        - Monitor remediation timelines.
        - Escalate overdue remediation.

5. Roles and Responsibilities

- **5.1 System Owners:**
    - Responsible for the security of their systems.
    - Ensure that vulnerability assessments are performed.
    - Implement remediation actions for identified vulnerabilities.
- **5.2 Security Team:**
    - Develop and maintain this program.
    - Conduct or oversee risk and vulnerability assessments.
    - Provide guidance and support on risk and vulnerability management.
    - Track and report on remediation activities.
    - Perform penetration testing.
- **5.3 IT Operations:**
    - Assist with vulnerability scanning and remediation.
    - Implement system and network configurations that support security.
    - Apply patches and updates in a timely manner.
- **5.4 Application Development Teams:**
    - Ensure that applications are developed with security in mind.
    - Participate in code reviews and security testing.
    - Address vulnerabilities identified during testing.
- **5.5 Management:**
    - Provide resources and support for the risk and vulnerability assessment program.
    - Ensure that risk and vulnerability management activities are integrated into the organization's overall security program.
    - Ensure compliance with this program.

6. Compliance

- **6.1 Program Compliance:** All Tellius personnel are required to comply with this program.
- **6.2 Non-Compliance:** Non-compliance with this program may result in disciplinary action, up to and including termination of employment or contracts, and potential legal consequences.
- **6.3 Program Review:** This program will be reviewed and updated at least annually or as needed to reflect changes in technology, threats, vulnerabilities, and business requirements.

7. Related Policies and Procedures

- (List other relevant policies and procedures, such as:)
    - Security Policy
    - Vulnerability Management Policy
    - Patch Management Policy
    - Incident Response Policy
    - Access Control Policy

Tellius Software Development Lifecycle (SDLC) Policy and Procedures

Policy Owner: VP of Engineering

Effective Date: 01/01/2025

1. Purpose

- This policy establishes the Software Development Lifecycle (SDLC) and Application Security practices for Tellius. It provides a framework for the secure and controlled development, testing, and deployment of software applications and systems to:
  - Ensure the security, reliability, and quality of all software developed, acquired, or maintained by Tellius.
  - Protect the confidentiality, integrity, and availability of Tellius data and systems.
  - Comply with relevant regulatory requirements, industry standards, and best practices, including the AICPA's Trust Services Criteria for SOC 2.
  - Establish a consistent, repeatable, and secure process for software development.

2. Scope

- This policy applies to all Tellius personnel and any external parties involved in the software development lifecycle, including but not limited to:
  - Software Engineers (Front-End, Back-End)
  - Data Engineers
  - Machine Learning Engineers
  - Product Managers
  - Designers
  - Quality Assurance (QA) Engineers
  - DevOps Engineers
  - Security Engineers
  - Contractors
  - Third-party vendors involved in software development or integration
- This policy encompasses all software applications, systems, and services developed, acquired, or maintained by Tellius, including:
  - Tellius application
  - APIs and SDKs
  - Cloud infrastructure and services
  - Data processing pipelines
  - Machine learning models and related code
  - Internal tools and systems

3. Policy Statements

- **Secure SDLC Framework:** Tellius follows a structured SDLC framework that incorporates security best practices into each phase. The SDLC phases include:
  - Planning
  - Design
  - Development
  - Testing

    - Deployment
    - Maintenance
- **Security by Design:** Security is a core consideration throughout the SDLC, not an add-on. Security requirements are identified, documented, and addressed in the initial planning and design phases.
- **Secure Coding Practices:** All software development adheres to secure coding practices and guidelines to minimize the introduction of vulnerabilities.
- **Testing and Quality Assurance:** Rigorous testing and quality assurance processes, including security testing, are conducted to verify software functionality, reliability, and security.
- **Change Management:** All software changes are managed through a controlled change management process to ensure that changes are authorized, tested, and implemented in a secure and documented manner.
- **Vulnerability Management:** A proactive vulnerability management program is in place to identify, assess, and remediate software vulnerabilities in a timely manner.
- **Access Control:** Access to development environments, code repositories, build systems, and deployment systems is restricted based on the principle of least privilege and job responsibilities.
- **Data Security:** Software development activities involving sensitive data adhere to data security policies and procedures, including data encryption, data masking, and data loss prevention measures.
- **Training and Awareness:** All personnel involved in the SDLC receive regular security training and awareness education to stay updated on secure development practices and security threats.
- **Incident Response:** A security incident response plan is in place to address and manage security incidents that may arise during the software development lifecycle.

4. Procedures

- **Planning**
    - **Requirements Analysis:**
        - Functional and non-functional requirements, including security requirements, are clearly defined, documented, and approved by relevant stakeholders.
        - Security requirements are derived from applicable laws, regulations, industry standards (e.g., OWASP), and risk assessments.
        - Data Privacy, Security risks are clearly identified and documented.
    - **Risk Assessment:**
        - Security risk assessments are conducted to identify potential threats and vulnerabilities early in the SDLC.
        - Risk assessments consider factors such as data sensitivity, system criticality, and potential impact.
    - **Project Planning:**
        - Project plans include security tasks, timelines, and resource allocation.
        - Security activities are integrated into the overall project schedule.
- **Design**
    - **Secure Design Principles:**
        - Software is designed using secure design principles, including:
            - Least privilege: Granting only the minimum necessary permissions.
            - Defense in depth: Implementing multiple layers of security controls.
            - Fail-safe defaults: Defaulting to a secure state.
            - Separation of duties: Dividing responsibilities to prevent single points of failure.
            - Principle of least astonishment
        - Resiliency: Design systems to be resilient and recover quickly from failure.
    - **Threat Modeling:**

        - Threat modeling is performed to identify potential attack vectors, vulnerabilities, and the impact of potential threats.
        - Threat modeling informs the design of security controls and testing strategies.
    - **Security Architecture Review:**
        - Security architecture reviews are conducted to evaluate the design for potential security weaknesses.
        - Reviews are performed by qualified security personnel or architects.
    - **API Security:**
        - APIs are designed with security as a priority, implementing authentication, authorization, input validation, and rate limiting.
- **Development**
    - **Secure Coding Standards:**
        - Developers adhere to secure coding standards and guidelines (e.g., OWASP Secure Coding Practices, CERT Coding Standards) for all programming languages used.
        - Code examples:
            - Input validation: All user-supplied input is validated to prevent injection attacks.
            - Output encoding: Data is properly encoded to prevent cross-site scripting (XSS).
            - Error handling: Errors are handled securely without exposing sensitive information.
            - Authentication and authorization: Secure mechanisms are used to verify user identity and enforce access control.
    - **Code Reviews:**
        - Peer code reviews are conducted to identify potential security flaws and ensure adherence to secure coding standards.
        - Code reviewers are trained in secure coding practices.
    - **Static Application Security Testing (SAST):**
        - SAST tools are used to automatically analyze source code for potential vulnerabilities.
        - SAST tools are integrated into the CI/CD pipeline where possible.
    - **Dependency Management:**
        - Software dependencies are managed using a centralized system.
        - Dependencies are regularly scanned for known vulnerabilities.
        - Only approved and trusted libraries and frameworks are used.
    - **Logging:**
        - Security events, errors, and warnings are logged to detect potential security issues.
        - Logged data is protected to prevent unauthorized access.
- **Testing**
    - **Security Testing:**
        - Security testing is performed to verify the effectiveness of security controls and identify vulnerabilities.
        - Security testing includes:
            - Vulnerability scanning: Automated scanning for known vulnerabilities.
            - Dynamic Application Security Testing (DAST): Testing the application in a running state to find vulnerabilities.
            - Penetration testing: Simulating real-world attacks to identify weaknesses.
            - Fuzz testing: Providing invalid, unexpected, or random data as inputs.
            - Manual code review: In-depth analysis of the code to find vulnerabilities that automated tools might miss.
    - **Test Environment:**
        - A separate and secure test environment is maintained for conducting testing.
        - Test data is anonymized or synthetic to protect sensitive information.
    - **Test Planning:**

        - Test plans include security test cases that cover identified security risks and requirements.
    - **Regression Testing:**
        - Regression tests are performed to ensure that new changes do not negatively impact existing functionality or security.
    - **QA Sign-off:**
        - The QA team is responsible for verifying that software meets both functional and security requirements before release.
- **Deployment**
    - **Change Management Process:**
        - All software deployments follow a documented and approved change management process.
        - The change management process includes:
            - Request for change (RFC) submission.
            - Impact analysis.
            - Testing and approval.
            - Backout plan.
            - Post-deployment validation.
    - **Deployment Environment Security:**
        - Deployment environments are secured to prevent unauthorized access.
        - Access to production systems is strictly controlled and audited.
    - **Deployment Procedures:**
        - Detailed deployment procedures are documented and followed.
        - Deployments are automated where possible to reduce manual errors and improve consistency.
    - **Post-Deployment Validation:**
        - Post-deployment security checks are performed to verify that the software is deployed securely and functioning as intended.
- **Maintenance**
    - **Vulnerability Management:**
        - Production systems and software are regularly scanned for vulnerabilities.
        - A process is in place to track, prioritize, and remediate identified vulnerabilities based on severity.
        - Security patches are applied in a timely manner following a defined schedule.
    - **Security Monitoring:**
        - Security monitoring and logging are implemented to detect and respond to security events.
        - Intrusion detection and prevention systems (IDPS) are used where appropriate.
    - **Incident Response:**
        - A security incident response plan is in place to handle security incidents, including:
            - Identification
            - Containment
            - Eradication
            - Recovery
            - Post-incident analysis
    - **Software Updates:**
        - Software is updated regularly to patch security vulnerabilities and ensure compatibility.

5. Responsibilities

- **Software Engineers:**
    - Adhere to secure coding practices and development standards.

    - Participate in code reviews and address identified security vulnerabilities.
    - Perform unit tests, and contribute to integration and system testing.
    - Document code and development processes.
- **QA Engineers:**
    - Develop and execute test plans, including security test cases.
    - Report and track identified defects and vulnerabilities.
    - Verify that software meets both functional and security requirements.
    - Participate in risk assessment and threat modeling.
- **DevOps Engineers:**
    - Establish and maintain secure development, testing, and production environments.
    - Implement security controls in the CI/CD pipeline.
    - Automate security testing and deployment processes.
    - Manage and monitor infrastructure security.
- **Security Engineers:**
    - Develop and maintain security policies, standards, and procedures.
    - Provide security training and guidance to development teams.
    - Conduct security assessments, penetration tests, and vulnerability scans.
    - Participate in incident response and security audits.
    - Perform threat modeling.
- **Product Managers:**
    - Incorporate security requirements into product planning and roadmaps.
    - Prioritize security features and bug fixes.
    - Ensure that development teams have the resources and support needed to develop secure software.
- **Management:**
    - Provide adequate resources and budget for security activities.
    - Promote a culture of security awareness and responsibility.
    - Ensure that all personnel are aware of and comply with this policy.
    - Support the implementation and enforcement of this policy.

6. Compliance

- **Policy Compliance:** All Tellius personnel and third parties are required to comply with this policy.
- **Non-Compliance:** Non-compliance with this policy may result in disciplinary action, up to and including termination of employment or contracts, and potential legal consequences.
- **Policy Review:** This policy will be reviewed and updated at least annually or as needed to reflect changes in technology, security threats, and business requirements.

7. Other Related Policies and Procedures

- Access Control Policy
- Change Control Policy and Procedure
- Risk and Vulnerability Assessment Program

Third-Party Management Policy

Policy Owner: Operations Lead

Effective Date: 06/21/2021

1. Purpose

To ensure protection of the organization's data and assets that are shared with, accessible to, or managed by suppliers, including external parties or third-party organizations such as service providers, vendors, and customers, and to maintain an agreed level of information security and service delivery in line with supplier agreements.

This document outlines a baseline of security controls that Tellius, Inc. expects partners and other third-party companies to meet when interacting with Tellius, Inc. Confidential data.

2. Scope

All data and information systems owned or used by Tellius, Inc. that are business critical and/or process, store, or transmit Confidential data. This policy applies to all employees of Tellius, Inc. and to all external parties, including but not limited to Tellius, Inc. consultants, contractors, business partners, vendors, suppliers, partners, outsourced service providers, and other third-party entities with access to Tellius, Inc. data, systems, networks, or system resources.

3. Policy

Information security requirements for mitigating the risks associated with supplier's access to the organization's assets shall be agreed with the supplier and documented.

For all service providers who may access Tellius, Inc. Confidential data, systems, or networks, proper due diligence shall be performed prior to provisioning access or engaging in processing activities. Information shall be maintained regarding which regulatory or certification requirements are managed by or impacted by each service provider, and which are managed by Tellius, Inc. as required. Applicable regulatory or certification requirements may include ISO 27001, SOC 2, PCI-DSS, CCPA, GDPR or other frameworks or regulations.

4. Information Security in Third-Party Relationships

Addressing Security in Agreements

Relevant information security requirements shall be established and agreed with each supplier that may access, process, store, or transmit Confidential data, or provide physical or virtual IT infrastructure components for Tellius, Inc..

For all service providers who may access Tellius, Inc. production systems, or who may impact the security of the Tellius, Inc. production environment, written agreements shall be maintained that include the service provider's acknowledgment of their responsibilities for the confidentiality of company and customer data, and any commitments regarding the integrity, availability, and/or privacy controls that they manage in order to meet the standards and requirements that Tellius, Inc. has established in accordance with Tellius, Inc.'s information security program or any relevant framework.

Technology Supply Chain

Tellius, Inc. will consider and assess risk associated with suppliers and the technology supply chain. Where warranted, agreements with suppliers shall include requirements to address the relevant information security risks associated with information and communications technology services and the product supply chain.

5. Third-Party Service Delivery Management

Monitoring & Review of Third-Party Services

Tellius, Inc. shall regularly monitor, review, and audit supplier service delivery. Supplier security and service delivery performance shall be reviewed at least annually.

Management of Changes to Third-Party Services

Changes to the provision of services by suppliers, including changes to agreements, services, technology, policies, procedures, or controls, shall be managed, taking account of the criticality of the business information, systems, and processes involved. Tellius, Inc. shall assess the risk of any material changes made by suppliers and make appropriate modifications to agreements and services accordingly.

6. Third-Party Risk Management

Tellius, Inc. will ensure that potential risks posed by sharing Confidential data are identified, documented and addressed according to this policy. Risk management plays an integral part in the governance and management of the organization at a strategic and operational level. The purpose of a partner and third-party security policy is to ensure that partnerships and services achieve their business plan aims and objectives, and are consistent with Tellius, Inc.'s requirements for information security.

Tellius, Inc. shall not share or transmit Confidential data to a third-party without first performing a third-party risk assessment and fully executing a written contract, statement of work or service agreement which describes expected service levels and any specific information security requirements.

7. Third-Party Security Standards

All third-parties must maintain reasonable organizational and technical controls as assessed by Tellius, Inc..

Assessment of third-parties which receive, process, or store Confidential data shall consider the following controls as applicable based on the service provided and the sensitivity of data stored, processed or exchanged.

Information Security Policy

Third-parties maintain information security policies supported by their executive management, which are regularly reviewed.

Risk Assessment & Treatment

Third-parties maintain programs that assess, evaluate, and manage information and technology risks.

Operations Security

Third-parties implement commercially reasonable practices and procedures designed, as appropriate, to maintain operations security. Protections may include:

- Technical testing
- Protection against malicious software
- Network protection and management
- Technical vulnerability management
- Logging and monitoring
- Incident response
- Business continuity planning

Access Control

Third-parties maintain a technical access control program.

Secure System Development

Third-parties maintain a secure development program consistent with industry software and systems development best practices including risk assessment, formal change management, code standards, code review and testing.

Physical & Environmental Security

If third-parties are storing or processing confidential data, their physical and environmental security controls should meet the requirements of the Tellius, Inc. Physical Security Policy.

Human Resources

Third-parties maintain human resource policies and processes which include criminal background checks for any employees or contractors who access Tellius, Inc. Confidential information.

Compliance & Legal

Tellius, Inc. shall consider all applicable regulations and laws when evaluating suppliers and third parties who will access, store, process or transmit Tellius, Inc. Confidential data. Third-party assessments should consider the following criteria:

- Protection of customer data, organizational records, and records retention and disposition
- Privacy of Personally Identifiable Information (PII)

8. Exceptions

Requests for an exception to this Policy must be submitted to the Operations Lead for approval.

9. Violations & Enforcement

Any known violations of this policy should be reported to the Operations Lead. Violations of this policy can result in immediate withdrawal or suspension of system and network privileges and/or disciplinary action in accordance with company procedures up to and including termination of employment.

Version	Date	Description	Author	Approved by

<1.0>	<29-Apr-2020>	<First Version>	<OWNER>	<APPROVER>